



DECEMBER 26, 2025

HACKING WEB SERVICES

MODULE 13

VYANKATESH ANDIL

TABLE OF CONTENTS

Contents

1: Web Servers & Attack Surface	1
1. Introduction to Web Servers	1
2. Objectives of Sniffing Attacks	1
3. Network Communication Basics (CEH Foundation)	1
3.1 Packet-Based Communication	1
3.2 Network Interface Card (NIC) Modes	2
4. Types of Sniffing	2
4.1 Passive Sniffing	2
4.2 Active Sniffing	2
5. Sniffing in Switched vs Hub Networks	3
5.1 Hub-Based Networks	3
5.2 Switched Networks	3
6. Risks and Impact of Sniffing	3
7. Sniffing Detection Challenges	3
8. Sniffing Countermeasures	3
9. MITRE ATT&CK Mapping	4
2: Vulnerable Protocols & Insecure Network Services	5
1. Introduction to Vulnerable Protocols	5
2. Plaintext vs Encrypted Protocols	5
2.1 Plaintext Protocols	5
2.2 Encrypted Protocols	5
3. Common Protocols Vulnerable to Sniffing	5
3.1 HTTP (Hypertext Transfer Protocol)	5
3.2 FTP (File Transfer Protocol)	6
3.3 Telnet	6
3.4 SMTP, POP3, IMAP	6
4. Authentication Exposure via Sniffing	7
4.1 Basic Authentication	7

TABLE OF CONTENTS

4.2 Session-Based Authentication	7
5. Real-World Sniffing Example.....	7
6. Risks and Impact of Insecure Protocols.....	7
7. Protocol-Level Mitigations.....	8
8. MITRE ATT&CK Mapping	8
3: Active Sniffing Techniques	9
1. Introduction to Active Sniffing	9
1.1 Definition of Active Sniffing	9
2. Why Active Sniffing Is Required in Switched Networks	9
2.1 Switched Network Behavior	9
2.2 Attacker Goal.....	9
3. ARP Poisoning (ARP Spoofing).....	9
3.1 ARP Protocol Overview	9
3.2 ARP Poisoning Technique	9
3.3 ARP Poisoning Workflow	10
3.4 Risks of ARP Poisoning.....	10
3.5 ARP Poisoning Mitigations.....	10
4. MAC Flooding	10
4.1 Definition	10
4.2 Attack Objective.....	10
4.3 Risks of MAC Flooding.....	11
4.4 MAC Flooding Mitigations	11
5. DHCP Starvation.....	11
5.1 Definition	11
5.2 Attack Impact.....	11
5.3 DHCP Starvation Mitigations	11
6. DNS Spoofing (Sniffing Support Attack)	12
6.1 Role in Sniffing.....	12
7. Risks and Impact of Active Sniffing.....	12
8. MITRE ATT&CK Mapping	12

TABLE OF CONTENTS

4: Sniffing Tools	13
1. Introduction to Sniffing Tools.....	13
2. Wireshark.....	13
2.1 Overview.....	13
2.2 Objectives.....	13
2.3 Working Methodology.....	13
2.4 Risks.....	14
2.5 Mitigations.....	14
2.6 MITRE ATT&CK Mapping.....	14
3. tcpdump.....	14
3.1 Overview.....	14
3.2 Objectives.....	14
3.3 Working Methodology.....	15
3.4 Risks.....	15
3.5 Mitigations.....	15
3.6 MITRE ATT&CK Mapping.....	15
4. Ettercap.....	15
4.1 Overview.....	15
4.2 Objectives.....	16
4.3 Working Methodology.....	16
4.4 Risks.....	16
4.5 Mitigations.....	16
4.6 MITRE ATT&CK Mapping.....	16
5. Bettercap.....	17
5.1 Overview.....	17
5.2 Objectives.....	17
5.3 Working Methodology.....	17
5.4 Risks.....	17
5.5 Mitigations.....	17
5.6 MITRE ATT&CK Mapping.....	17

TABLE OF CONTENTS

6. Hardware Sniffers	18
6.1 Overview	18
6.2 Risks	18
6.3 Mitigations	18
7. Comparative Summary of Sniffing Tools.....	18
5: Sniffing Detection & Countermeasures	20
1. Introduction to Sniffing Detection	20
2. Detecting Passive Sniffing.....	20
2.1 Challenges	20
2.2 Detection Techniques	20
3. Detecting Active Sniffing.....	20
3.1 ARP Poisoning Detection.....	20
3.2 MAC Flooding Detection.....	21
3.3 DHCP Starvation Detection	21
4. Sniffing Detection Tools.....	21
4.1 IDS/IPS.....	21
4.2 Network Monitoring Tools.....	21
4.3 ARP Watch Tools	21
5. Sniffing Countermeasures	22
5.1 Encryption	22
5.2 Switch Security Features.....	22
5.3 Network Segmentation.....	22
5.4 Authentication Hardening.....	22
6. Enterprise-Level Defensive Controls	22
7. Risks of Improper Countermeasures	23
8. MITRE ATT&CK Mapping	23
Consolidated Summary, Real-World Scenarios	24
1. Consolidated Overview of Sniffing	24
2. Sniffing Lifecycle	24
3. Passive vs Active Sniffing	24

TABLE OF CONTENTS

4. Real-World Sniffing Attack Scenarios	25
4.1 Public Wi-Fi Sniffing.....	25
4.2 Corporate LAN MITM Attack.....	25
4.3 Credential Harvesting.....	25
5. Sniffing & MITRE ATT&CK	25
6. Risk Assessment.....	26
6.1 Threats	26
6.2 Impact	26
6.3 Likelihood	26
7. Sniffing Mitigation Strategy	26
7.1 Technical Controls	26
7.2 Administrative Controls	26
7.3 Physical Controls	27
8. Sniffing.....	27
8.1 Common Exam Traps	27
8.2 High-Value One-Liners.....	27
9. How to Use This Module Content.....	27
10. Final Conclusion.....	28
POC's	29
1. web server footprinting	29
Netcat	29
Telnet	29
2. Enumerate Web Server Information	30
2. Crack FTP Credentials.....	33

1: WEB SERVERS & ATTACK SURFACE

1: Web Servers & Attack Surface

1. INTRODUCTION TO WEB SERVERS

Sniffing is the process of **capturing, intercepting, and analyzing network traffic** as it flows across a network. A sniffer operates by placing a network interface card (NIC) into **promiscuous or monitor mode**, allowing it to capture packets not addressed to the attacker's system.

In ethical hacking, sniffing is used to:

- Identify insecure protocols
- Detect data leakage
- Analyze network behavior

In malicious contexts, sniffing enables **credential theft and data interception**.

2. OBJECTIVES OF SNIFFING ATTACKS

Attackers use sniffing to:

- Capture usernames and passwords
- Steal session cookies
- Monitor sensitive communications
- Perform man-in-the-middle attacks
- Gather intelligence for lateral movement

Sniffing primarily compromises **confidentiality**.

3. NETWORK COMMUNICATION BASICS (CEH FOUNDATION)

3.1 Packet-Based Communication

All network communication is divided into **packets**, each containing:

- Source IP
- Destination IP

1: WEB SERVERS & ATTACK SURFACE

- Protocol information
- Payload (data)

Sniffers analyze these packet components.

3.2 Network Interface Card (NIC) Modes

3.2.1 Normal Mode

- Captures only packets addressed to the host

3.2.2 Promiscuous Mode

- Captures all packets on the network segment
- Used in **wired sniffing**

3.2.3 Monitor Mode

- Captures wireless packets
 - Used in **Wi-Fi sniffing**
-

4. TYPES OF SNIFFING

4.1 Passive Sniffing

- No packet modification
 - Difficult to detect
 - Works on hub-based or wireless networks
-

4.2 Active Sniffing

- Involves traffic manipulation
 - Uses ARP poisoning, MAC flooding
 - Detectable
 - Required on switched networks
-

1: WEB SERVERS & ATTACK SURFACE

5. SNIFFING IN SWITCHED VS HUB NETWORKS

5.1 Hub-Based Networks

- Broadcast traffic to all ports
- Passive sniffing is sufficient

5.2 Switched Networks

- Traffic sent only to intended destination
 - Requires **active sniffing techniques**
-

6. RISKS AND IMPACT OF SNIFFING

- Credential compromise
- Session hijacking
- Privacy breaches
- Corporate espionage

Sniffing often acts as a **precursor to larger attacks**.

7. SNIFFING DETECTION CHALLENGES

- Passive sniffers leave no footprint
 - Encrypted traffic reduces visibility
 - Attackers blend into normal traffic
-

8. SNIFFING COUNTERMEASURES

- Encrypted protocols (HTTPS, SSH)
 - Network segmentation
 - Switch port security
 - IDS/IPS monitoring
-

1: WEB SERVERS & ATTACK SURFACE

9. MITRE ATT&CK MAPPING

Sniffing Activity	MITRE Tactic	Technique ID	Technique Name
Packet Capture	Credential Access	T1040	Network Sniffing
Traffic Interception	Collection	TA0009	Collection

10. CEH Exam-Oriented Notes

- Sniffing targets **data in transit**
- Promiscuous mode ≠ Monitor mode
- Passive sniffing is stealthier
- Active sniffing is required on switches
- Encryption defeats sniffing effectiveness

2: VULNERABLE PROTOCOLS & INSECURE NETWORK SERVICES

2: Vulnerable Protocols & Insecure Network Services

1. INTRODUCTION TO VULNERABLE PROTOCOLS

Network protocols define **how data is transmitted** between systems. Many legacy protocols transmit data in **plaintext**, making them highly vulnerable to sniffing attacks. Sniffers can easily capture and read this data without decryption.

2. PLAINTEXT VS ENCRYPTED PROTOCOLS

2.1 Plaintext Protocols

Transmit data **without encryption**, allowing attackers to read:

- Credentials
 - Emails
 - Commands
 - File contents
-

2.2 Encrypted Protocols

Use cryptographic techniques to protect data in transit.

Examples:

- HTTPS instead of HTTP
 - SSH instead of Telnet
-

3. COMMON PROTOCOLS VULNERABLE TO SNIFFING

3.1 HTTP (Hypertext Transfer Protocol)

3.1.1 Description

HTTP transmits web data in plaintext.

3.1.2 Sniffing Risk

- URLs
-

2: VULNERABLE PROTOCOLS & INSECURE NETWORK SERVICES

- Session cookies
- Login credentials

Attackers can hijack sessions using captured cookies.

3.2 FTP (File Transfer Protocol)

3.2.1 Description

FTP transmits:

- Username
- Password
- File contents in plaintext.

3.2.2 Sniffing Risk

- Credential theft
 - Unauthorized file access
-

3.3 Telnet

3.3.1 Description

Telnet provides remote login access without encryption.

3.2.2 Sniffing Risk

- Complete exposure of login credentials
 - Command interception
-

3.4 SMTP, POP3, IMAP

3.4.1 Description

Email protocols often operate in plaintext by default.

3.4.2 Sniffing Risk

- Email content exposure
-

2: VULNERABLE PROTOCOLS & INSECURE NETWORK SERVICES

- Credential capture
-

4. AUTHENTICATION EXPOSURE VIA SNIFFING

4.1 Basic Authentication

- Encoded using Base64
 - Easily decoded after capture
-

4.2 Session-Based Authentication

- Cookies transmitted in plaintext
 - Enables session hijacking
-

5. REAL-WORLD SNIFFING EXAMPLE

1. Victim logs into HTTP website
2. Attacker captures packets
3. Credentials visible in packet payload
4. Attacker reuses credentials

This attack requires **no malware installation**.

6. RISKS AND IMPACT OF INSECURE PROTOCOLS

- Account compromise
- Data theft
- Regulatory violations
- Man-in-the-middle attacks

2: VULNERABLE PROTOCOLS & INSECURE NETWORK SERVICES

7. PROTOCOL-LEVEL MITIGATIONS

- Use HTTPS, SFTP, SSH
 - Disable insecure services
 - Enforce TLS encryption
 - Strong authentication mechanisms
-

8. MITRE ATT&CK MAPPING

Protocol Risk	MITRE Tactic	Technique ID	Technique Name
Credential Capture	Credential Access	T1040	Network Sniffing
Session Hijacking	Collection	T1557	Adversary-in-the-Middle

9. CEH Exam-Oriented Notes

- HTTP ≠ secure
- FTP transmits passwords in plaintext
- Telnet is insecure by design
- Base64 is encoding, **not encryption**
- HTTPS mitigates sniffing risks

3: ACTIVE SNIFFING TECHNIQUES

3: Active Sniffing Techniques

1. INTRODUCTION TO ACTIVE SNIFFING

1.1 Definition of Active Sniffing

Active sniffing is a technique where an attacker **actively injects packets or manipulates network traffic** to force data to flow through the attacker's system. This is required in **switched networks**, where traffic is normally sent only to the intended recipient.

Unlike passive sniffing, **active sniffing is detectable** because it alters normal network behavior.

2. WHY ACTIVE SNIFFING IS REQUIRED IN SWITCHED NETWORKS

2.1 Switched Network Behavior

- Switches maintain a **MAC address table**
- Traffic is forwarded only to the destination port
- Passive sniffing does not work

2.2 Attacker Goal

- Break switch logic
 - Redirect traffic to attacker's system
 - Perform Man-in-the-Middle (MITM)
-

3. ARP POISONING (ARP SPOOFING)

3.1 ARP Protocol Overview

Address Resolution Protocol (ARP) maps:

- IP address → MAC address

ARP has **no authentication**, making it vulnerable.

3.2 ARP Poisoning Technique

The attacker sends **forged ARP replies** to:

3: ACTIVE SNIFFING TECHNIQUES

- Victim: "I am the gateway"
- Gateway: "I am the victim"

This positions the attacker **between both parties**.

3.3 ARP Poisoning Workflow

1. Attacker sends fake ARP replies
 2. ARP tables of victim and gateway are poisoned
 3. Traffic flows through attacker
 4. Packets are sniffed, modified, or dropped
-

3.4 Risks of ARP Poisoning

- Credential theft
 - Session hijacking
 - Data manipulation
-

3.5 ARP Poisoning Mitigations

- Static ARP entries
 - ARP inspection (DAI)
 - Encrypted protocols
 - IDS/IPS detection
-

4. MAC FLOODING

4.1 Definition

MAC flooding overwhelms a switch by sending **thousands of fake MAC addresses**, filling its MAC table.

4.2 Attack Objective

When the MAC table is full:

3: ACTIVE SNIFFING TECHNIQUES

- Switch behaves like a hub
 - Broadcasts traffic to all ports
 - Passive sniffing becomes possible
-

4.3 Risks of MAC Flooding

- Network performance degradation
 - Unauthorized packet capture
-

4.4 MAC Flooding Mitigations

- Port security
 - MAC address limits
 - Switch hardening
-

5. DHCP STARVATION

5.1 Definition

DHCP starvation exhausts the DHCP server's IP address pool by sending **multiple fake DHCP requests**.

5.2 Attack Impact

- Legitimate users cannot obtain IP addresses
 - Attacker may introduce a **rogue DHCP server**
-

5.3 DHCP Starvation Mitigations

- DHCP snooping
- IP source guard
- Port security

3: ACTIVE SNIFFING TECHNIQUES

6. DNS SPOOFING (SNIFFING SUPPORT ATTACK)

6.1 Role in Sniffing

DNS spoofing redirects victims to malicious servers, often combined with sniffing for credential capture.

7. RISKS AND IMPACT OF ACTIVE SNIFFING

- Complete compromise of confidentiality
- Network instability
- Data integrity loss

Active sniffing often escalates into **MITM attacks**.

8. MITRE ATT&CK MAPPING

Technique	MITRE Tactic	Technique ID	Technique Name
ARP Poisoning	Credential Access	T1040	Network Sniffing
MITM	Collection	T1557	Adversary-in-the-Middle
MAC Flooding	Defense Evasion	T1200	Hardware Additions
DHCP Starvation	Impact	T1499	Denial of Service

9. CEH Exam-Oriented Notes

- ARP has **no authentication**
- ARP poisoning enables MITM
- MAC flooding forces switch to act as hub
- DHCP starvation leads to DoS
- Active sniffing is **detectable**

4: SNIFFING TOOLS

4: Sniffing Tools

1. INTRODUCTION TO SNIFFING TOOLS

Sniffing tools are software or hardware utilities used to **capture, analyze, and manipulate network traffic**. Ethical hackers use these tools to:

- Identify insecure protocols
- Validate encryption enforcement
- Detect data leakage

Attackers misuse the same tools for **credential theft and MITM attacks**.

2. WIRESHARK

2.1 Overview

Wireshark is a **GUI-based packet analyzer** widely used for network troubleshooting, forensics, and security analysis.

2.2 Objectives

- Capture live network traffic
 - Inspect packet headers and payloads
 - Identify insecure protocols
 - Analyze session behavior
-

2.3 Working Methodology

1. NIC set to promiscuous/monitor mode
2. Packets captured in real time
3. Protocol dissection performed
4. Filters applied for analysis

4: SNIFFING TOOLS

2.4 Risks

- Sensitive data exposure
 - Requires proper authorization
 - Large captures may affect performance
-

2.5 Mitigations

- Encrypt network traffic
 - Restrict administrative access
 - Monitor promiscuous mode usage
-

2.6 MITRE ATT&CK Mapping

- **T1040 – Network Sniffing**
-

2.7 CEH Exam Notes

- Wireshark is **passive by default**
 - Cannot decrypt encrypted traffic without keys
 - Supports protocol-level analysis
-

3. TCPDUMP

3.1 Overview

tcpdump is a **command-line packet analyzer** used in Linux-based environments for lightweight traffic capture.

3.2 Objectives

- Capture packets in headless systems
 - Automate packet collection
-

4: SNIFFING TOOLS

- Analyze traffic remotely
-

3.3 Working Methodology

- Uses libpcap
 - Captures packets based on filters
 - Outputs raw packet data
-

3.4 Risks

- Plaintext data exposure
 - Requires elevated privileges
-

3.5 Mitigations

- Limit sudo/root access
 - Log command usage
-

3.6 MITRE ATT&CK Mapping

- **T1040 – Network Sniffing**
-

3.7 CEH Exam Notes

- Lightweight alternative to Wireshark
 - Often used in servers
 - Supports Berkeley Packet Filter (BPF)
-

4. ETTERCAP

4.1 Overview

Ettercap is a **powerful MITM attack tool** supporting sniffing, traffic modification, and credential capture.

4: SNIFFING TOOLS

4.2 Objectives

- Perform ARP poisoning
 - Capture credentials
 - Modify packets in transit
-

4.3 Working Methodology

1. ARP poisoning initiated
 2. Traffic redirected through attacker
 3. Packet capture and manipulation
-

4.4 Risks

- Network disruption
 - Easily detectable
 - Legal consequences if misused
-

4.5 Mitigations

- Dynamic ARP Inspection
 - IDS/IPS alerts
 - Encrypted protocols
-

4.6 MITRE ATT&CK Mapping

- **T1557 – Adversary-in-the-Middle**
 - **T1040 – Network Sniffing**
-

4.7 CEH Exam Notes

- Ettercap = **active sniffing**
- Used mainly in switched networks

4: SNIFFING TOOLS

- Supports plugins
-

5. BETTERCAP

5.1 Overview

Bettercap is a **modern MITM framework**, often considered a successor to Ettercap.

5.2 Objectives

- Perform MITM attacks
 - Credential harvesting
 - Network reconnaissance
-

5.3 Working Methodology

- Modular architecture
 - ARP, DNS, HTTP spoofing
 - Scriptable attacks
-

5.4 Risks

- High detectability
 - Network instability
-

5.5 Mitigations

- Network monitoring
- Encrypted traffic
- ARP inspection

5.6 MITRE ATT&CK Mapping

- **T1557 – Adversary-in-the-Middle**

4: SNIFFING TOOLS

5.7 CEH Exam Notes

- Bettercap is **more advanced than Ettercap**
 - Used for real-world MITM scenarios
-

6. HARDWARE SNIFFERS

6.1 Overview

Physical devices used to capture traffic directly from network links.

6.2 Risks

- Difficult to detect
 - Require physical access
-

6.3 Mitigations

- Physical security
 - Network access control
-

7. COMPARATIVE SUMMARY OF SNIFFING TOOLS

Tool	Type	Sniffing Mode	Key Use
Wireshark	GUI	Passive	Packet analysis
tcpdump	CLI	Passive	Server analysis
Ettercap	MITM	Active	Credential capture
Bettercap	MITM	Active	Advanced MITM

8. CEH Exam-Oriented Notes

4: SNIFFING TOOLS

- Wireshark ≠ MITM tool
- Ettercap/Bettercap = **active sniffing**
- tcpdump is CLI-based
- MITM attacks rely on ARP poisoning

5: SNIFFING DETECTION & COUNTERMEASURES

5: Sniffing Detection & Countermeasures

1. INTRODUCTION TO SNIFFING DETECTION

Sniffing detection focuses on identifying **unauthorized packet capture or MITM activity** within a network. Detection is challenging, especially for **passive sniffing**, because it does not alter traffic.

2. DETECTING PASSIVE SNIFFING

2.1 Challenges

- No packet injection
 - No traffic modification
 - No obvious network footprint
-

2.2 Detection Techniques

- Monitoring NIC promiscuous mode
 - ARP cache analysis
 - Latency and packet loss anomalies
-

3. DETECTING ACTIVE SNIFFING

Active sniffing techniques generate detectable signs.

3.1 ARP Poisoning Detection

Indicators:

- Multiple MAC addresses mapped to one IP
 - Frequent ARP replies
 - Inconsistent ARP cache entries
-

5: SNIFFING DETECTION & COUNTERMEASURES

3.2 MAC Flooding Detection

Indicators:

- Rapid MAC table changes
 - Excessive broadcast traffic
-

3.3 DHCP Starvation Detection

Indicators:

- Sudden exhaustion of DHCP pool
 - Numerous DHCP requests
-

4. SNIFFING DETECTION TOOLS

4.1 IDS/IPS

- Detect abnormal ARP traffic
 - Identify MITM patterns
-

4.2 Network Monitoring Tools

- Snort
 - Zeek (Bro)
 - Wireshark (for analysis)
-

4.3 ARP Watch Tools

- arpswatch
- XArp

5: SNIFFING DETECTION & COUNTERMEASURES

5. SNIFFING COUNTERMEASURES

5.1 Encryption

- HTTPS, SSH, TLS
- VPN tunnels

Encryption renders sniffed data unusable.

5.2 Switch Security Features

- Port security
 - Dynamic ARP Inspection (DAI)
 - DHCP snooping
-

5.3 Network Segmentation

- VLANs
 - Zero Trust architecture
-

5.4 Authentication Hardening

- Multi-factor authentication
 - Secure cookie flags
-

6. ENTERPRISE-LEVEL DEFENSIVE CONTROLS

- Network Access Control (NAC)
- Endpoint Detection & Response (EDR)
- Security Information and Event Management (SIEM)

5: SNIFFING DETECTION & COUNTERMEASURES

7. RISKS OF IMPROPER COUNTERMEASURES

- False sense of security
 - Encrypted malware traffic
 - Misconfigured IDS/IPS
-

8. MITRE ATT&CK MAPPING

Defense Area	MITRE Tactic	Technique ID	Technique Name
Sniffing Detection	Defense Evasion	T1562	Impair Defenses
MITM Prevention	Collection	T1557	Adversary-in-the-Middle
Encryption Use	Credential Access	T1040	Network Sniffing (Mitigation)

9. CEH Exam-Oriented Notes (Part 5)

- Passive sniffing is hard to detect
- ARP poisoning is noisy
- Encryption is the strongest defense
- Switch security features are critical
- IDS detects **behavior**, not intent

CONSOLIDATED SUMMARY, REAL-WORLD SCENARIOS

Consolidated Summary, Real-World Scenarios

1. CONSOLIDATED OVERVIEW OF SNIFFING

Sniffing is a network-based attack technique focused on **intercepting data in transit**. It primarily targets **confidentiality** but often leads to further attacks such as **session hijacking, credential theft, and MITM attacks**.

Sniffing itself is not malware; it is a **technique** that can be used by both attackers and defenders.

2. SNIFFING LIFECYCLE

1. **Network Access** – Attacker connects to target network
 2. **Interface Configuration** – NIC in promiscuous/monitor mode
 3. **Traffic Redirection (Active)** – ARP poisoning / MAC flooding
 4. **Packet Capture** – Sniffer collects traffic
 5. **Analysis** – Credentials, cookies, data extracted
 6. **Post-Exploitation** – Lateral movement, escalation
-

3. PASSIVE VS ACTIVE SNIFFING

Feature	Passive Sniffing	Active Sniffing
Traffic Injection	No	Yes
Detectability	Very Low	High
Switch Requirement	Not effective	Required
Example	Wireshark	Ettercap

CONSOLIDATED SUMMARY, REAL-WORLD SCENARIOS

4. REAL-WORLD SNIFFING ATTACK SCENARIOS

4.1 Public Wi-Fi Sniffing

- Open Wi-Fi networks
 - No encryption
 - Attackers sniff credentials and cookies
-

4.2 Corporate LAN MITM Attack

- ARP poisoning inside LAN
 - Session hijacking
 - Credential capture
-

4.3 Credential Harvesting

- FTP/Telnet usage
 - Sniffer captures plaintext credentials
-

5. SNIFFING & MITRE ATT&CK

Sniffing Phase	MITRE Tactic
----------------	--------------

Packet Capture	Credential Access
----------------	-------------------

MITM	Collection
------	------------

Traffic Redirection Defense Evasion

Session Hijacking Impact

MITRE provides **behavior-based classification**, not tool-based.

CONSOLIDATED SUMMARY, REAL-WORLD SCENARIOS

6. RISK ASSESSMENT

6.1 Threats

- Insecure protocols
 - Poor switch configuration
 - Weak encryption
-

6.2 Impact

- Data breaches
 - Account compromise
 - Regulatory penalties
-

6.3 Likelihood

High in:

- Public Wi-Fi
 - Legacy networks
 - Flat LAN architectures
-

7. SNIFFING MITIGATION STRATEGY

7.1 Technical Controls

- Enforce encryption
 - Secure switching
 - IDS/IPS
-

7.2 Administrative Controls

- Security policies
- Network audits

CONSOLIDATED SUMMARY, REAL-WORLD SCENARIOS

- User awareness
-

7.3 Physical Controls

- Controlled network access
 - Secure switch rooms
-

8. SNIFFING

8.1 Common Exam Traps

- Confusing sniffing with malware
 - Assuming HTTPS can be sniffed easily
 - Mixing up promiscuous and monitor mode
 - Forgetting ARP's lack of authentication
-

8.2 High-Value One-Liners

- "Sniffing targets data in transit"
 - "ARP poisoning enables MITM"
 - "Encryption defeats sniffing"
 - "Active sniffing is detectable"
-

9. HOW TO USE THIS MODULE CONTENT

For CEH Exam

- Memorize tables and comparisons
- Focus on ARP, MITM, protocols

For Reports

- Use structured format
-

CONSOLIDATED SUMMARY, REAL-WORLD SCENARIOS

- Map attacks to MITRE

For Labs

- Practice Ettercap, Wireshark
 - Observe packet flows
-

10. FINAL CONCLUSION

Sniffing remains a **fundamental yet powerful network attack technique**. While modern encryption reduces its effectiveness, misconfigurations and legacy systems still leave organizations vulnerable. Ethical hackers must understand sniffing to **identify weaknesses and implement robust defenses**.

POC's

1. WEB SERVER FOOTPRINTING

Netcat

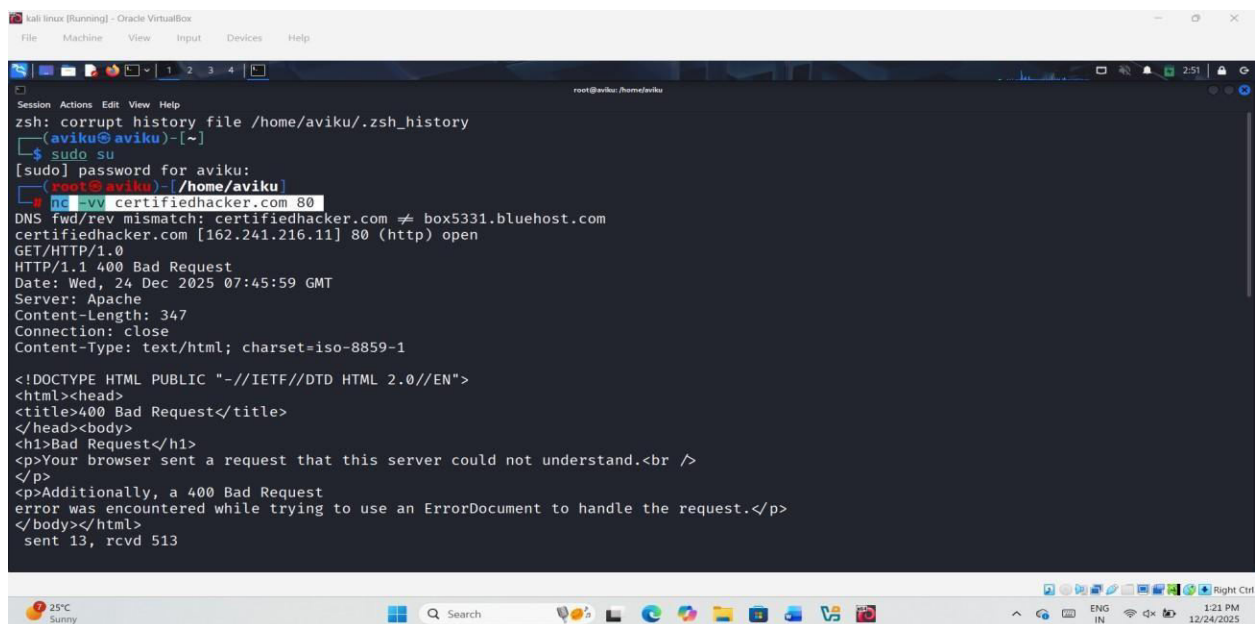
Netcat is a versatile networking utility that allows reading and writing of data over network connections using the TCP/IP protocol. It is commonly used as a reliable backend tool, either operated directly or integrated into other programs and scripts. Netcat is also widely used for network debugging, testing, and exploration purposes.

Telnet

Telnet is a client-server based network protocol that enables remote login sessions over the Internet or local area networks (LANs). It allows a user's terminal to emulate a terminal on a remote computer. However, Telnet has significant security weaknesses, including:

- Lack of data encryption during transmission
- Absence of a secure authentication mechanism

Due to these weaknesses, Telnet is often used in security testing for **bannergrabbing attacks**, where it queries HTTP servers to extract information such as the **Server** field from HTTP response headers. nc -vv certifiedhacker.com 80



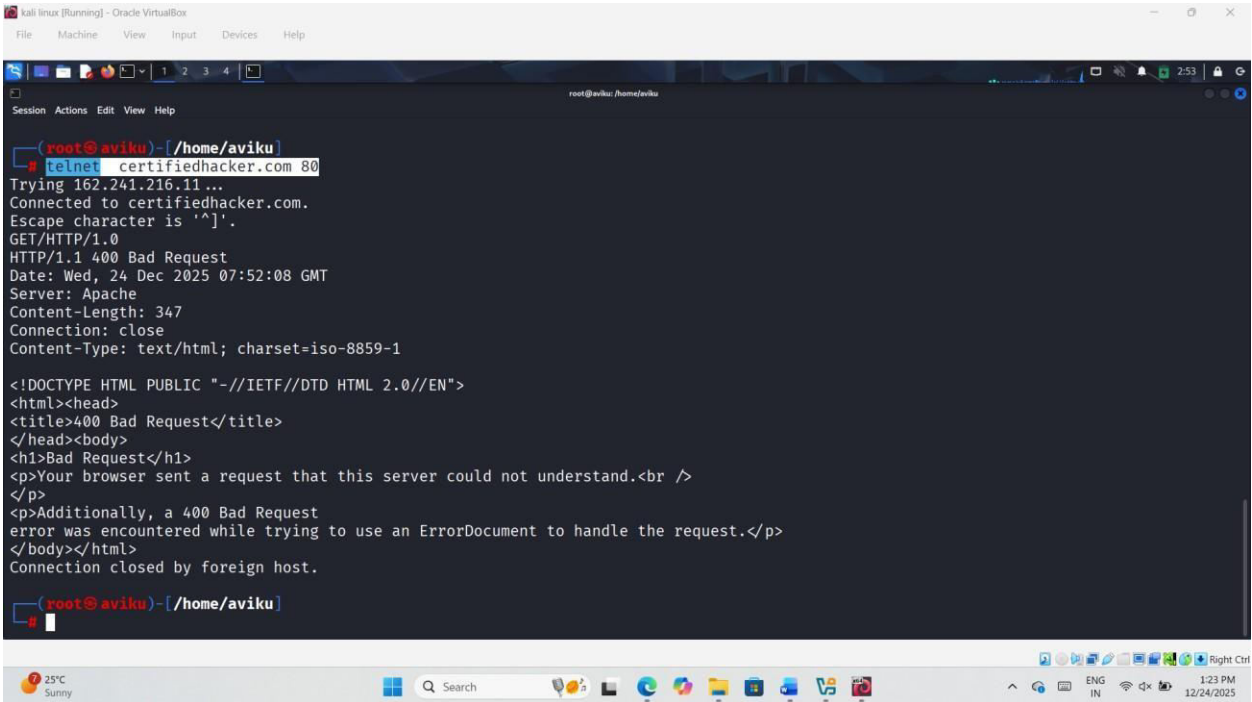
```
kali linux (Running) - Oracle VM VirtualBox
File Machine View Input Devices Help

zsh: corrupt history file /home/aviku/.zsh_history
(aviku@aviku)~$ sudo su
[sudo] password for aviku:
(aviku@aviku)~$ nc -vv certifiedhacker.com 80
DNS fwd/rev mismatch: certifiedhacker.com != box5331.bluehost.com
certifiedhacker.com [162.241.216.11] 80 (http) open
GET/HTTP/1.0
HTTP/1.1 400 Bad Request
Date: Wed, 24 Dec 2025 07:45:59 GMT
Server: Apache
Content-Length: 347
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<p>Additionally, a 400 Bad Request
error was encountered while trying to use an ErrorDocument to handle the request.</p>
</body></html>
sent 13, rcvd 513
```

POC'S

telnet certifiedhacker.com 80



```
kali linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

root@kali: /home/aviku

root@kali:~# telnet certifiedhacker.com 80
Trying 162.241.216.11...
Connected to certifiedhacker.com.
Escape character is '^]'.
GET/HTTP/1.0
HTTP/1.1 400 Bad Request
Date: Wed, 24 Dec 2025 07:52:08 GMT
Server: Apache
Content-Length: 347
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<p>Additionally, a 400 Bad Request
error was encountered while trying to use an ErrorDocument to handle the request.</p>
</body></html>
Connection closed by foreign host.

root@kali:~#
```

2. ENUMERATE WEB SERVER INFORMATION

nmap -sV --script=http-enum [certifiedhacker.com](https://www.goodshopping.com)

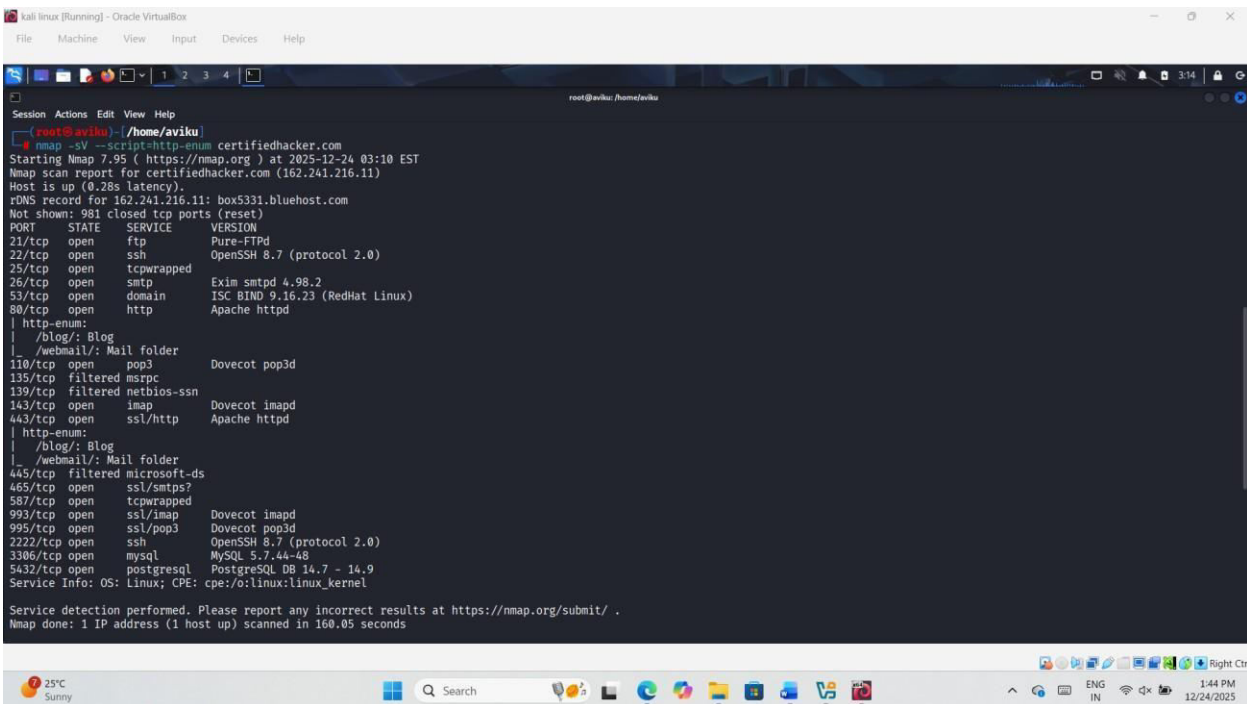
Explanation

- nmap → Network scanning tool
- -sV → Detects service versions running on open ports
- --script=http-enum → Uses the NSE script to enumerate web server directories, applications, and files
- www.goodshopping.com → Target website being enumerated

Purpose

This command enumerates the www.goodshopping.com web server to identify accessible directories, web applications, and potential misconfigurations that could expose security weaknesses.

POC'S



```
kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: /home/aviku
root@aviku: ~/home/aviku
# nmap -sV --script=http-enum certifiedhacker.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-24 03:10 EST
Nmap scan report for certifiedhacker.com (162.241.216.11)
Host is up (0.28s latency).
rDNS record for 162.241.216.11: box5331.bluehost.com
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Pure-FTPd
22/tcp    open  ssh          OpenSSH 8.7 (protocol 2.0)
25/tcp    open  tcpwrapped
26/tcp    open  smtp         Exim smtpd 4.96.2
53/tcp    open  domain       ISC BIND 9.16.23 (RedHat Linux)
80/tcp    open  http         Apache httpd
| http-enum:
| /blog/: Blog
| /webmail/: Mail folder
|_ /webmail/: Mail folder
110/tcp   open  pop3         Dovecot pop3d
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
143/tcp   open  imap         Dovecot imapd
443/tcp   open  ssl/http     Apache httpd
| http-enum:
| /blog/: Blog
| /webmail/: Mail folder
|_ /webmail/: Mail folder
445/tcp   filtered microsoft-ds
465/tcp   open  ssl/smtp     Dovecot smtpd
587/tcp   open  tcpwrapped
993/tcp   open  ssl/imap     Dovecot imapd
995/tcp   open  ssl/pop3     Dovecot pop3d
2222/tcp  open  ssh          OpenSSH 8.7 (protocol 2.0)
3306/tcp  open  mysql        MySQL 5.7.44-48
5432/tcp  open  postgresql   PostgreSQL DB 14.7 - 14.9
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 160.05 seconds
```

nmap --script hostmap-bfk --script-args hostmap-bfk.prefix=hostmap- www.goodshopping.com

Explanation

- nmap → Network scanning tool
- --script hostmap-bfk → Uses the **hostmap-bfk** NSE script to discover virtual hosts and related domain names
- --script-args hostmap-bfk.prefix=hostmap- → Specifies the prefix used during brute-force host discovery
- www.goodshopping.com → Target website

Purpose

This command is used to **enumerate virtual hosts and related subdomains** associated with the target web server, which helps identify additional attack surfaces during web server Footprinting.

POC'S

```
kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help

zsh: corrupt history file /home/aviku/.zsh_history
(aviku@aviku)-[~]
$ sudo su
[sudo] password for aviku:
(root@aviku)-[/home/aviku]
# nmap --script hostmap-bfk --script-args hostmap-bfk.prefix=hostmap- www.goodshopping.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-24 02:59 EST
Nmap scan report for www.goodshopping.com (3.33.130.190)
Host is up (0.020s latency).
Other addresses for www.goodshopping.com (not scanned): 15.197.148.33
rDNS record for 3.33.130.190: a2aa9ff50de748dbe.awsglobalaccelerator.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 23.36 seconds

(root@aviku)-[/home/aviku]
# nmap --script hostmap-bfk --script-args hostmap-bfk.prefix=hostmap- www.testfire.net
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-24 03:01 EST
Nmap scan report for www.testfire.net (65.61.137.117)
Host is up (0.039s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 35.50 seconds
```

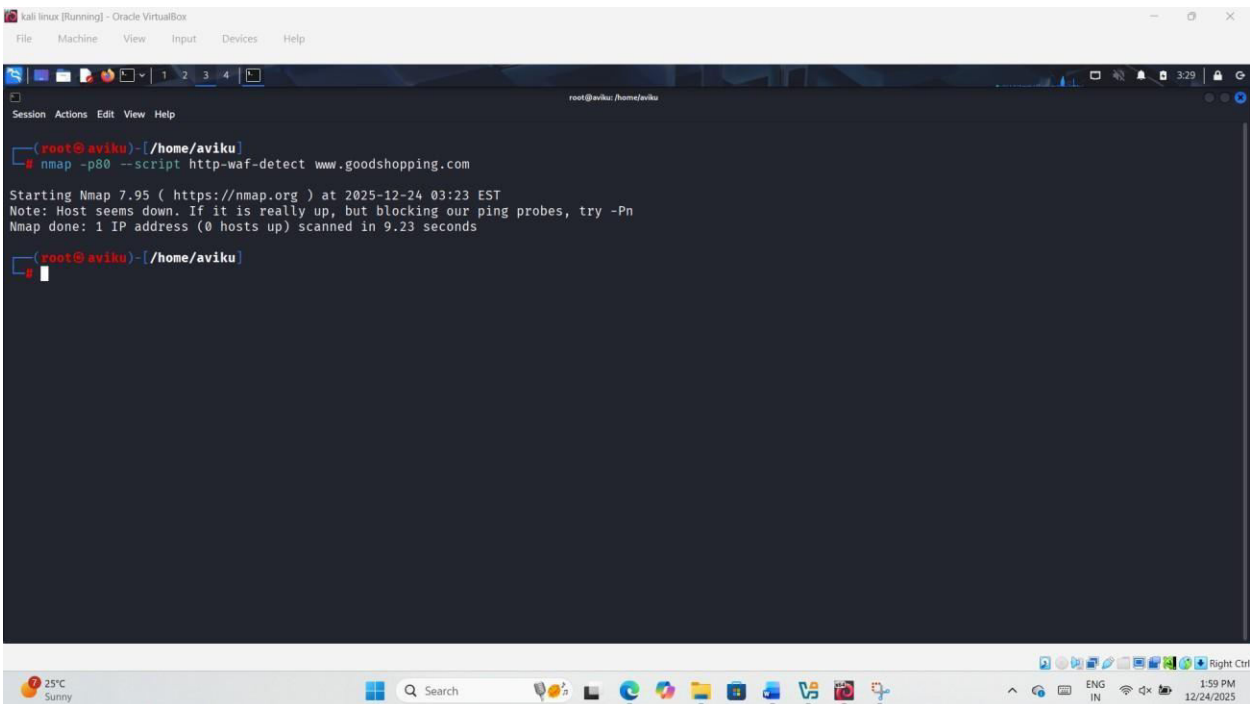
`nmap -p80 --script http-waf-detect www.goodshopping.com`

Explanation:

- `nmap` → the tool itself
- `-p80` → scan only port 80 (HTTP)
- `--script http-waf-detect` → run the NSE script that detects Web Application Firewalls (WAFs)
- `www.goodshopping.com` → target domain

The purpose of this command is to identify whether a Web Application Firewall is active on the target web server, which is a critical step in ethical hacking and penetration testing.

POC'S



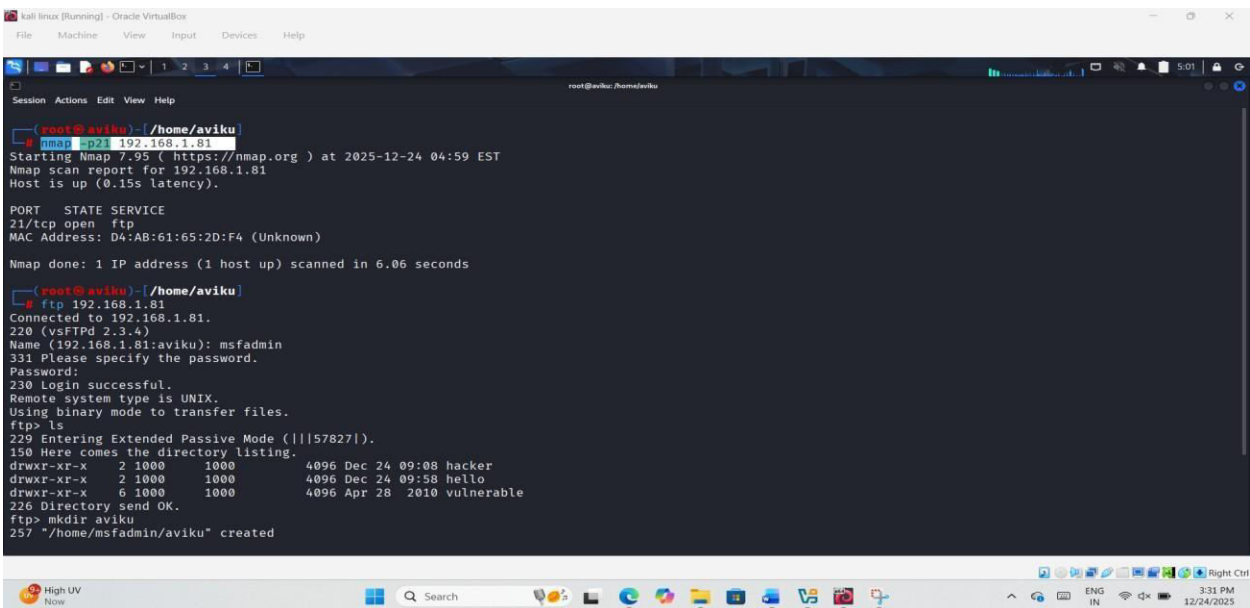
```
kali linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

root@aviku: /home/aviku
root@aviku:~# nmap -p80 --script http-waf-detect www.goodshopping.com

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-24 03:23 EST
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 9.23 seconds

root@aviku:~#
```

2. CRACK FTP CREDENTIALS



```
kali linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

root@aviku: /home/aviku
root@aviku:~# nmap -p21 192.168.1.81

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-24 04:59 EST
Nmap scan report for 192.168.1.81
Host is up (0.13s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: D4:AB:61:65:2D:F4 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 6.06 seconds

root@aviku:~# ftp 192.168.1.81
Connected to 192.168.1.81.
220 (vsFTPd 2.3.4)
Name (192.168.1.81:aviku): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||57827|).
150 Here comes the directory listing.
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:08 hacker
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:58 hello
drwxr-xr-x  6 1000    1000          4096 Apr 28 2010 vulnerable
226 Directory send OK.
ftp> mkdir aviku
257 "/home/msfadmin/aviku" created
```

[ftp 192.168.1.81](ftp://192.168.1.81)

POC'S

The screenshot shows a Kali Linux terminal window with the following content:

```

kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: ~/home/aviku

Session Actions Edit View Help
MAC Address: D4:AB:61:65:2D:F4 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 6.06 seconds

root@aviku: ~/home/aviku
ftp 192.168.1.81
Connected to 192.168.1.81.
220 (vsFTPd 2.3.4)
Name (192.168.1.81:aviku): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||57827|).
150 Here comes the directory listing.
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:08 hacker
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:58 hello
drwxr-xr-x  6 1000    1000          4096 Apr 28 2010 vulnerable
226 Directory send OK.
ftp> mkdir aviku
257 "/home/msfadmin/aviku" created
ftp> ls
229 Entering Extended Passive Mode (|||26746|).
150 Here comes the directory listing.
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:59 aviku
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:08 hacker
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:58 hello
drwxr-xr-x  6 1000    1000          4096 Apr 28 2010 vulnerable
226 Directory send OK.
ftp>

```

```
hydra -L /home/attacker/Desktop/Wordlists/Username.txt -P  
/home/attacker/Desktop/Wordlists/Passwords.txt ftp://192.168.1.81
```

Or

```
hydra -L usernames.txt -P rockyou.txt ftp://192.168.1.81
```

The screenshot shows a Kali Linux terminal window with the following content:

```

root@kali:~/Documents
File Machine View Input Devices Help

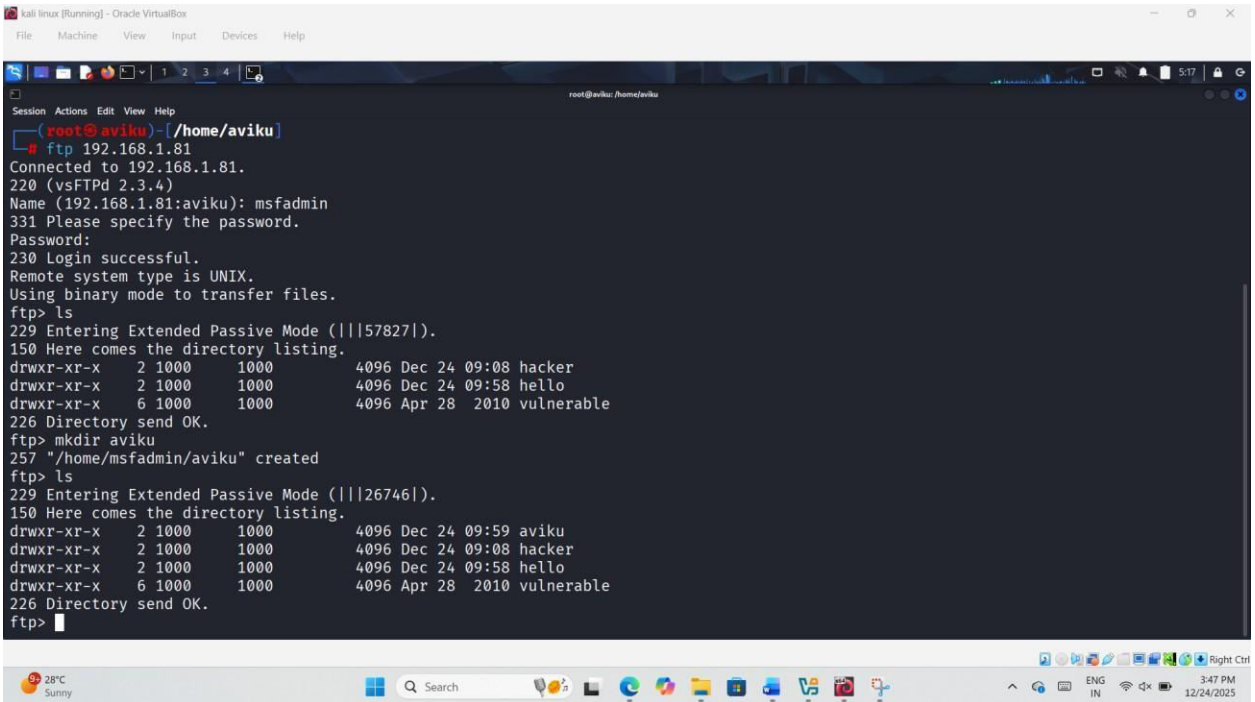
root@kali:~/Documents
zsh: corrupt history file /home/aviku/.zsh_history
root@kali:~/Documents
$ sudo su
[sudo] password for aviku:
root@kali:~/Documents
# ls
acmetix-13-kali-linux  demo.txt  eccouncil_subdomains.txt  exploit2.exe  hash1.txt  Photon  recon2.txt  shell_gpt  test.txt  'Untitled Sessio
'amit shah.txt'       'Elon Musk.txt'  evildgms2  exploit3.exe  hash2.txt  Pictures  rockyou.txt  ShellPhish  'Untitled Session.session'  'Untitled Sessio
Burgsuite-Professional Desktop  evildgms2  exploits1.exe  'Jeff bezoss.txt'  Public  secret.rar  Templates  'Untitled Session.session.data'  'Untitled Sessio
Cm-Pksh               Documents  exploit.exe  'k1le.zip'      Music  secret.txt  Test  'Untitled Session.session.txt'  usernames.txt
data.txt              Downloads  exploit1.exe  go              pdfhash.txt  Raven-Store  test.pdf  'Untitled Session.session.log'  Videos

root@kali:~/Documents
# hydra -u usernames.txt -P rockyou.txt ftp://192.168.1.81
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-24 05:11:39
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws a
[DATA] max 16 tasks per 1 server, overall 16 tasks, 733284 login tries (l:81476/p:p), ~45831 tries per task
[DATA] attacking ftp://192.168.1.81:21/
[21][ftp] host: 192.168.1.81  login: msfadmin  password: msfadmin
[21][ftp] host: 192.168.1.81  login: msfadmin  password: msfadmin
[STATUS] 271.00 tries/min, 271 tries in 00:01h, 733013 to do in 45:05h, 16 active
[STATUS] 277.33 tries/min, 832 tries in 00:03h, 732452 to do in 44:02h, 16 active

```


POC'S

ftp 192.168.1.81



```
kali linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

root@aviku: /home/aviku
root@aviku ~# ftp 192.168.1.81
Connected to 192.168.1.81.
220 (vsFTPd 2.3.4)
Name (192.168.1.81:aviku): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||57827|).
150 Here comes the directory listing.
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:08 hacker
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:58 hello
drwxr-xr-x  6 1000    1000          4096 Apr 28 2010 vulnerable
226 Directory send OK.
ftp> mkdir aviku
257 "/home/msfadmin/aviku" created
ftp> ls
229 Entering Extended Passive Mode (|||26746|).
150 Here comes the directory listing.
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:59 aviku
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:08 hacker
drwxr-xr-x  2 1000    1000          4096 Dec 24 09:58 hello
drwxr-xr-x  6 1000    1000          4096 Apr 28 2010 vulnerable
226 Directory send OK.
ftp>
```